

Desarrollo seguro de web y apps



ACTIVIDAD 2:

Caso de uso práctico SecDevOps

Estudiante: Iris Carolina Fernández González

Profesor: Rafael Sánchez Gómez

Grado: Ingeniería de la Ciberseguridad

Curso Académico: 2025-2026

SECURE (ENTORNO SEGURO)

- **SAST – ESLint**

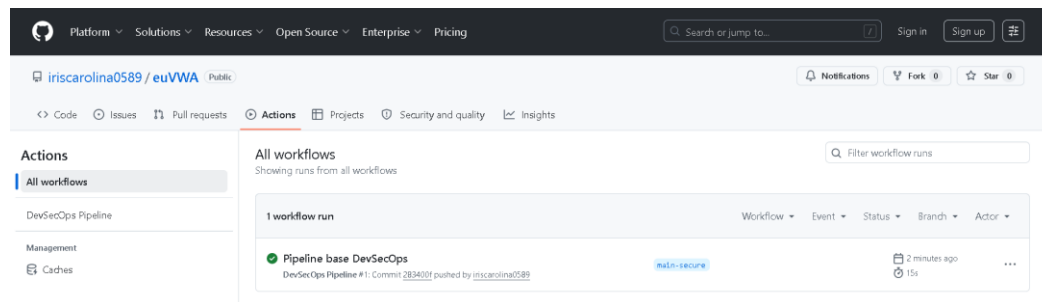
El análisis estático de código (SAST) mediante ESLint se ejecuta correctamente sin detectar vulnerabilidades ni errores de calidad de código en la rama secure.

```
Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-secure)
$ npx eslint .

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-secure)
$
```

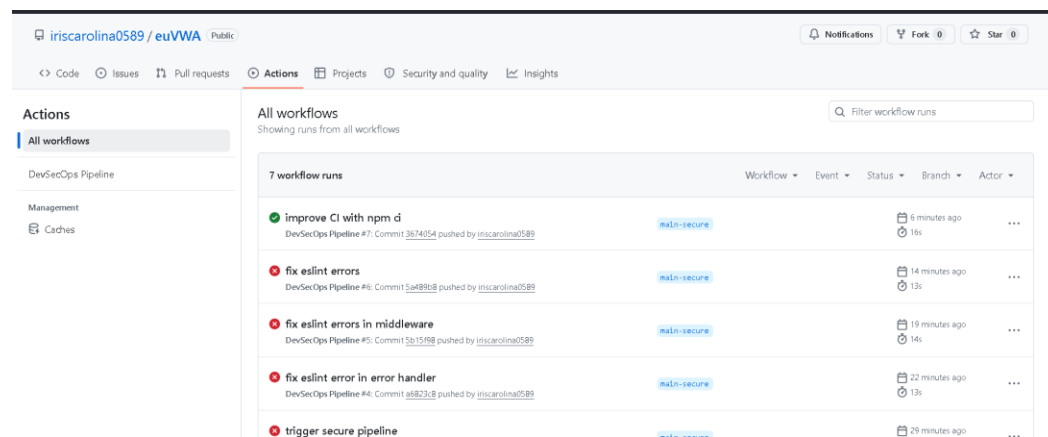
- **CI/CD Pipeline**

Ejecución inicial del pipeline CI/CD en rama secure, validando la configuración base del entorno DevSecOps con Node.js y GitHub Actions.



- **Pipeline final**

El pipeline CI/CD se ejecuta completamente en la rama secure, incluyendo instalación de dependencias, análisis SAST y verificación de ejecución, finalizando con estado exitoso.



- **DAST - Análisis dinámico**

Se realizó un análisis dinámico de seguridad utilizando OWASP ZAP en modo baseline sobre la aplicación en ejecución.

El análisis no detectó vulnerabilidades críticas ni de alta severidad (FAIL = 0).

Las alertas detectadas corresponden principalmente a mejoras de hardening de cabeceras HTTP, como:

- Falta de Content Security Policy (CSP)
- Falta de X-Content-Type-Options
- Falta de Anti-clickjacking header
- Permisos de política no definidos

Estos hallazgos no representan vulnerabilidades explotables críticas, sino recomendaciones de seguridad para endurecimiento del servidor web.

```
Windows PowerShell
PS C:\Users\Mario\euVMA> docker run -t -v ${PWD}:/zap/wrk ghcr.io/zaproxy/zaproxy:stable zap-baseline.py -t http://host.docker.internal:3000 -r zap-secure.html
Using the Automation Framework
Total of 3 URLs
PASS: Vulnerable JS Library (Powered by Retire.js) [10003]
PASS: In Page Banner Information Leak [10009]
PASS: Cookie No HttpOnly Flag [10010]
PASS: Cookie Without Secure Flag [10011]
PASS: Re-examine Cache-control Directives [10015]
PASS: Cross-Domain JavaScript Source File Inclusion [10017]
PASS: Content-Type Header Missing [10019]
PASS: Information Disclosure - Debug Error Messages [10023]
PASS: Information Disclosure - Sensitive Information in URL [10024]
PASS: Information Disclosure - Sensitive Information in HTTP Referrer Header [10025]
PASS: HTTP Parameter Override [10026]
PASS: Information Disclosure - Suspicious Comments [10027]
PASS: Off-site Redirect [10028]
PASS: Cookie Poisoning [10029]
PASS: User Controllable Charset [10030]
PASS: User Controllable HTML Element Attribute (Potential XSS) [10031]
PASS: Viewstate [10032]
PASS: Directory Browsing [10033]
PASS: Heartbleed OpenSSL Vulnerability (Indicative) [10034]
PASS: Strict-Transport-Security Header [10035]
PASS: HTTP Server Response Header [10036]
PASS: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037]
PASS: X-Backend-Server Header Information Leak [10039]
PASS: Secure Pages Include Mixed Content [10040]
PASS: HTTP to HTTPS Insecure Transition in Form Post [10041]
PASS: HTTPS to HTTP Insecure Transition in Form Post [10042]
PASS: User Controllable JavaScript Event (XSS) [10043]
PASS: Big Redirect Detected (Potential Sensitive Information Leak) [10044]
PASS: Retrieved from Cache [10050]
PASS: X-ChromeLogger-Data (XCOLD) Header Information Leak [10052]
PASS: Cookie without SameSite Attribute [10054]
PASS: CSP [10055]
PASS: X-Debug-Token Information Leak [10056]
PASS: Username Hash Found [10057]
PASS: X-AspNet-Version Response Header [10061]
PASS: PII Disclosure [10062]
```

```

PASS: Application Error Disclosure [90022]
PASS: WSDL File Detection [90030]
PASS: Loosely Scoped Cookie [90033]
WARN-NEW: Missing Anti-clickjacking Header [10020] x 1
http://host.docker.internal:3000 (200 OK)
WARN-NEW: X-Content-Type-Options Header Missing [10021] x 1
http://host.docker.internal:3000 (200 OK)
WARN-NEW: Content Security Policy (CSP) Header Not Set [10038] x 3
http://host.docker.internal:3000 (200 OK)
http://host.docker.internal:3000/robots.txt (404 Not Found)
http://host.docker.internal:3000/sitemap.xml (404 Not Found)
WARN-NEW: Storable and Cacheable Content [10049] x 3
http://host.docker.internal:3000 (200 OK)
http://host.docker.internal:3000/robots.txt (404 Not Found)
http://host.docker.internal:3000/sitemap.xml (404 Not Found)
WARN-NEW: Permissions Policy Header Not Set [10063] x 3
http://host.docker.internal:3000 (200 OK)
http://host.docker.internal:3000/robots.txt (404 Not Found)
http://host.docker.internal:3000/sitemap.xml (404 Not Found)
WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 3
http://host.docker.internal:3000 (200 OK)
http://host.docker.internal:3000 (200 OK)
http://host.docker.internal:3000 (200 OK)
FAIL-NEW: 0 FAIL-INPROG: 0 WARN-NEW: 6 WARN-INPROG: 0 INFO: 0 IGNORE: 0 PASS: 61
PS C:\Users\Mario\euVWA>

```

```

1 <!DOCTYPE html>
2 <html>
3 <head>
4 <META http-equiv="Content-Type" content="text/html; charset=UTF-8" />
5 <title>ZAP Scanning Report</title>
6 <style type="text/css">
7 body {
8   font-family: "Helvetica Neue", Helvetica, Arial, sans-serif;
9   color: #000;
10  font-size: 13px;
11 }
12
13 h1 {
14   text-align: center;
15   font-weight: bold;
16   font-size: 32px;
17 }
18
19 h3 {
20   font-size: 16px;
21 }
22
23 table {
24   border: none;
25   font-size: 13px;
26 }
27
28 td, th {
29   padding: 3px 4px;
30   word-break: break-word;
31 }
32
33 th {
34   font-weight: bold;
35   background-color: #666666;
36 }

```

Pasos:

```

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ git checkout main-secure -- eslint.config.mjs

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ git add eslint.config.mjs
git commit -m "add eslint config to vulnerable branch"
git push origin main-vulnerable
[main-vulnerable c2d540e] add eslint config to vulnerable branch
1 file changed, 8 insertions(+)
create mode 100644 eslint.config.mjs
Enumerating objects: 4, done.
Counting objects: 100% (4/4), done.
Delta compression using up to 20 threads
Compressing objects: 100% (3/3), done.
Writing objects: 100% (3/3), 488 bytes | 488.00 KiB/s, done.
Total 3 (delta 1), reused 1 (delta 0), pack-reused 0 (from 0)
remote: Resolving deltas: 100% (1/1), completed with 1 local object.
To https://github.com/iriscarolina0589/euVWA.git
1d43c75..c2d540e main-vulnerable -> main-vulnerable

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$

```

Se añade el archivo de configuración de ESLint a la rama vulnerable para permitir la ejecución del análisis SAST dentro del pipeline CI/CD.

```
Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ npm install

up to date, audited 81 packages in 920ms

24 packages are looking for funding
  run `npm fund` for details

1 moderate severity vulnerability

To address all issues, run:
  npm audit fix

Run `npm audit` for details.

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ npm install eslint @eslint/js globals --save-dev

added 69 packages, and audited 150 packages in 5s

42 packages are looking for funding
  run `npm fund` for details

1 moderate severity vulnerability

To address all issues, run:
  npm audit fix

Run `npm audit` for details.
```

Se instalan las dependencias necesarias para ESLint en la rama vulnerable, permitiendo la ejecución del análisis SAST dentro del pipeline CI/CD.

Creación de Dockerfile seguro con hardening de contenedor

```
Dockerfile
1  # Imagen base ligera
2  FROM node:18-alpine
3
4  # Crear usuario no-root (hardening)
5  RUN addgroup -S appgroup && adduser -S appuser -G appgroup
6
7  # Directorio de trabajo
8  WORKDIR /app
9
10 # Copiar dependencias primero (mejor cache)
11 COPY package*.json ./
12
13 # Instalar dependencias sin dev (más seguro)
14 RUN npm ci --omit=dev
15
16 # Copiar el resto del código
17 COPY . .
18
19 # Cambiar permisos al usuario no-root
20 RUN chown -R appuser:appgroup /app
21
22 # Usar usuario no-root
23 USER appuser
24
25 # Exponer puerto
26 EXPOSE 3000
27
28 # Comando de ejecución
29 CMD ["node", "main-secure/src/app.js"]
```

Se implementa un Dockerfile seguro utilizando una imagen ligera basada en Node.js Alpine, ejecución con usuario no-root y reducción de superficie de ataque mediante instalación controlada de dependencias.

Construcción de imagen Docker segura desde el contexto del proyecto

```
Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ docker build -t euVWA-secure .
[+] Building 25.5s (13/13) FINISHED                                docker:desktop-linux
=> [internal] load build definition from Dockerfile                0.0s
=> => transferring dockerfile: 622B                                0.0s
=> [internal] load metadata for docker.io/library/node:18-alpine  1.6s
=> [auth] library/node:pull token for registry-1.docker.io        0.0s
=> [internal] load .dockerignore                                    0.0s
=> => transferring context: 2B                                       0.0s
=> [1/7] FROM docker.io/library/node:18-alpine@sha256:8d6421d663b4c28fd3ebc498332f24 4.2s
=> => resolve docker.io/library/node:18-alpine@sha256:8d6421d663b4c28fd3ebc498332f24 0.0s
=> => sha256:25ff2da83641908f65c3a74d80409d6b1b62ccfaab220b9ea70b80df5a2 446B / 446B 0.2s
=> => sha256:dd71dde834b5c203d162902e6b8994cb2309ae049a0eabc4efea1 40.01MB / 40.01MB 2.9s
=> => sha256:1e5a4c89cee5c0826c540ab06d4b6b491c96eda01837f430bd47f0d 1.26MB / 1.26MB 1.3s
=> => sha256:f18232174bc91741fdf3da96d85011092101a032a93a388b79e99e6 3.64MB / 3.64MB 1.4s
=> => extracting sha256:f18232174bc91741fdf3da96d85011092101a032a93a388b79e99e69c2d5 0.2s
=> => extracting sha256:dd71dde834b5c203d162902e6b8994cb2309ae049a0eabc4efea161b2b5a 1.1s
=> => extracting sha256:1e5a4c89cee5c0826c540ab06d4b6b491c96eda01837f430bd47f0d26702 0.0s
=> => extracting sha256:25ff2da83641908f65c3a74d80409d6b1b62ccfaab220b9ea70b80df5a2e 0.0s
=> [internal] load build context                                    15.6s
=> => transferring context: 55.88MB                                  15.5s
=> [2/7] RUN addgroup -S appgroup && adduser -S appuser -G appgroup 0.4s
=> [3/7] WORKDIR /app                                             0.0s
=> [4/7] COPY package*.json ./                                    0.1s
=> [5/7] RUN npm ci --omit=dev                                    2.1s
=> [6/7] COPY . .                                                 0.3s
=> [7/7] RUN chown -R appuser:appgroup /app                      2.8s
=> exporting to image                                             2.8s
=> => exporting layers                                              1.2s
=> => exporting manifest sha256:26bacd5ae9bd279e9523f60d280c3020c2001306364d3211f169 0.0s
=> => exporting config sha256:0d2dda28b7b569aa11e7b44c99d46c9be5f103a7813c8e055ee796 0.0s
=> => exporting attestation manifest sha256:587d11ed63a801feeb5ac84d03674d353e94a8dc 0.0s
=> => exporting manifest list sha256:3918e7d4563c89a60197869278b660c9af47d8cbcd3500a 0.0s
=> => naming to docker.io/library/euVWA-secure:latest              0.0s
=> => unpacking to docker.io/library/euVWA-secure:latest           1.6s

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
```

Se construye la imagen Docker del proyecto desde la raíz del repositorio, asegurando el contexto completo de la aplicación y aplicando buenas prácticas de contenedorización segura.

```
Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ docker run -p 3000:3000 euVWA-secure
Servidor SECURE en http://localhost:3000
```

Se ejecuta el contenedor Docker de la aplicación segura en entorno local, validando su funcionamiento aislado dentro del entorno de ejecución controlado.

Escaneo de vulnerabilidades de imagen Docker con Trivy

Se realiza el análisis de la imagen Docker del sistema utilizando Trivy, detectando vulnerabilidades en el sistema operativo base (Alpine) y en dependencias Node.js instaladas en el contenedor.

```
MINGW64/c/Users/Mario
$ trivy --v
Version: 0.70.0

Mario@DESKTOP-RUB30FD MINGW64 --
$ trivy image euVWA-secure
2026-05-28T04:13:13-04:00 INFO [vulndb] Need to update DB...
2026-05-28T04:13:13-04:00 INFO [vulndb] Downloading vulnerability DB...
2026-05-28T04:13:13-04:00 INFO [vulndb] Downloading artifact... repo="mirror.gcr.io/aquasec/trivy-db:2"
93.32 MiB / 93.32 MiB [-----] 100.00% 14.08 MiB p/s 6.9s
2026-05-28T04:13:21-04:00 INFO [vulndb] Artifact successfully downloaded repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-05-28T04:13:21-04:00 INFO [vuln] Vulnerability scanning is enabled
2026-05-28T04:13:21-04:00 INFO [secret] Secret scanning is enabled
2026-05-28T04:13:21-04:00 INFO [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-05-28T04:13:21-04:00 INFO [secret] Please see https://trivy.dev/docs/v0.70/guide/scanner/secret#recommendation for faster secret detection
2026-05-28T04:13:23-04:00 INFO [alpine] Detecting vulnerabilities... os.version="3.21" repository="3.21" pkg.num=17
2026-05-28T04:13:23-04:00 INFO [alpine] Number of language-specific files: num=1
2026-05-28T04:13:23-04:00 INFO [node-pkg] Detecting vulnerabilities...
2026-05-28T04:13:23-04:00 WARN Using severities from other vendors for some vulnerabilities. Read https://trivy.dev/docs/v0.70/guide/scanner/vulnerability#severity-selection for details.
2026-05-28T04:13:23-04:00 INFO Table result includes only package filenames. Use '--format json' option to get the full path to the package file.

Report Summary
+-----+-----+-----+-----+-----+-----+-----+-----+
| Type | Vulnerabilities | Secrets | Target | | | | |
+-----+-----+-----+-----+-----+-----+-----+-----+
| euVWA-secure (alpine 3.21.3) | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| app/node_modules/@eslint-community/eslint-utils/node_modules/eslint-visitor-key- | node-pkg | 0 | - | | |
| s/package.json | | | | | | | |
| | | | | | | | |
| app/node_modules/@eslint-community/eslint-utils/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
| app/node_modules/@eslint-community/regexpp/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
| app/node_modules/@eslint/config-array/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
| app/node_modules/@eslint/config-helpers/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
| app/node_modules/@eslint/core/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
| app/node_modules/@eslint/js/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
| app/node_modules/@eslint/object-schema/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
| app/node_modules/@eslint/plugin-kit/package.json | | | | | | | |
| | node-pkg | 0 | | | | | |
```

app/node_modules/@eslint/plugin-kit/package.json					
node-pkg	0	-			
app/node_modules/@humanfs/core/package.json					
node-pkg	0	-			
app/node_modules/@humanfs/node/package.json					
node-pkg	0	-			
app/node_modules/@humanfs/types/package.json					
node-pkg	0	-			
app/node_modules/@humanwhocodes/module-importer/package.json					
node-pkg	0	-			
app/node_modules/@humanwhocodes/retry/package.json					
node-pkg	0	-			
app/node_modules/@types/esrecurse/package.json					
node-pkg	0	-			
app/node_modules/@types/estree/package.json					
node-pkg	0	-			
app/node_modules/@types/json-schema/package.json					
node-pkg	0	-			
app/node_modules/accepts/package.json					
node-pkg	0	-			
app/node_modules/acorn-jsx/package.json					
node-pkg	0	-			
app/node_modules/acorn/package.json					
node-pkg	0	-			
app/node_modules/ajv/package.json					
node-pkg	0	-			
app/node_modules/append-field/package.json					
node-pkg	0	-			
app/node_modules/balanced-match/package.json					
node-pkg	0	-			
app/node_modules/body-parser/package.json					
node-pkg	0	-			
app/node_modules/brace-expansion/package.json					
node-pkg	0	-			
app/node_modules/buffer-from/package.json					
node-pkg	0	-			
app/node_modules/busboy/package.json					
node-pkg	0	-			

euwva-secure (alpine 3.21.3)
=====

Total: 50 (UNKNOWN: 0, LOW: 19, MEDIUM: 14, HIGH: 15, CRITICAL: 2)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
busybox	CVE-2024-58251	MEDIUM	fixed	1.37.0-r12	1.37.0-r14	In netstat in BusyBox through 1.37.0, local users can launch of networ... https://avd.aquasec.com/nvd/cve-2024-58251
	CVE-2025-46394	LOW				In tar in BusyBox through 1.37.0, a TAR archive can have filenames... https://avd.aquasec.com/nvd/cve-2025-46394
busybox-binsh	CVE-2024-58251	MEDIUM				In netstat in BusyBox through 1.37.0, local users can launch of networ... https://avd.aquasec.com/nvd/cve-2024-58251
	CVE-2025-46394	LOW				In tar in BusyBox through 1.37.0, a TAR archive can have filenames... https://avd.aquasec.com/nvd/cve-2025-46394
libcrypto3	CVE-2026-31789	CRITICAL		3.3.3-r0	3.3.7-r0	openssl: OpenSSL: Heap buffer overFlow on 32-bit systems from large X.509 certificate... https://avd.aquasec.com/nvd/cve-2026-31789
	CVE-2025-15467	HIGH			3.3.6-r0	openssl: OpenSSL: Remote code execution or Denial of Service via oversized Initialization... https://avd.aquasec.com/nvd/cve-2025-15467
	CVE-2025-69421				openssl: OpenSSL: Denial of Service via malformed PKCS#12 file processing https://avd.aquasec.com/nvd/cve-2025-69421	
	CVE-2026-28387	3.3.7-r0			openssl: OpenSSL: Arbitrary code execution due to use-after-free in DANE TLSA authentication... https://avd.aquasec.com/nvd/cve-2026-28387	
	CVE-2026-28388				openssl: OpenSSL: Denial of Service due to NULL pointer dereference in delta... https://avd.aquasec.com/nvd/cve-2026-28388	
	CVE-2026-28389				openssl: OpenSSL: Denial of Service vulnerability in CMS processing https://avd.aquasec.com/nvd/cve-2026-28389	
	CVE-2026-28390				openssl: OpenSSL: Denial of Service due to NULL pointer dereference in CMS... https://avd.aquasec.com/nvd/cve-2026-28390	

Node.js (node-pkg)
=====

Total: 16 (UNKNOWN: 0, LOW: 2, MEDIUM: 3, HIGH: 11, CRITICAL: 0)

Library Title	Vulnerability	Severity	Status	Installed Version	Fixed Version	
brace-expansion (package.json)	CVE-2026-33750	MEDIUM	fixed	2.0.1	5.0.5, 3.0.2, 2.0.3, 1.1.13	brace-expansion: brace-expansion: Denial of Service via zero
						step value in brace pattern... https://avd.aquasec.com/nvd/cve-2026-33750
	CVE-2025-5889	LOW		2.0.2, 1.1.12, 3.0.1, 4.0.1		A vulnerability was found in juliangruber brace-expansion up to 1.1.11 ... https://avd.aquasec.com/nvd/cve-2025-5889
cross-spawn (package.json)	CVE-2024-21538	HIGH		7.0.3	7.0.5, 6.0.6	CVE-2024-21538 affecting package reaper for versions less than 3.1.1-15 https://avd.aquasec.com/nvd/cve-2024-21538
diff (package.json)	CVE-2026-24001	LOW		5.2.0	8.0.3, 5.2.2, 4.0.4, 3.5.1	jsdiff: denial of service vulnerability in parsePatch and applyPatch https://avd.aquasec.com/nvd/cve-2026-24001
glob (package.json)	CVE-2025-64756	HIGH		10.4.2	11.1.0, 10.5.0	glob CLI: Command injection via -c/--cmd executes matches with shell:true https://avd.aquasec.com/nvd/cve-2025-64756
ip-address (package.json)	CVE-2026-42338	MEDIUM		9.0.5	10.1.1	ip-address is a library for parsing and manipulating IPv4 and IPv6 add...

Trivy identifica vulnerabilidades en dependencias del proyecto, específicamente en paquetes npm utilizados dentro del contenedor, evidenciando riesgos en la cadena de suministro.

Generación de SBOM en formato CycloneDX

```
Windows PowerShell ~
$ trivy image --format cyclonedx -o sbom.json euwva-secure
2026-05-28T04:33:56-04:00 INFO "--format cyclonedx" disables security scanning. Specify "--scanners vuln" explicitly if you want to include vulnerabilities in the "cyclonedx" report.
2026-05-28T04:33:58-04:00 INFO Detected OS family="alpine" version="3.21.3"
2026-05-28T04:33:58-04:00 INFO Number of language-specific files num=1
```

Análisis de vulnerabilidades a partir del SBOM

```
Windows PowerShell ~
$ trivy sbom sbom.json
2026-05-28T04:35:16-04:00 INFO [vuln] Vulnerability scanning is enabled
2026-05-28T04:35:16-04:00 INFO Detected SBOM format format="cyclonedx-json"
2026-05-28T04:35:16-04:00 INFO Detected OS family="alpine" version="3.21.3"
2026-05-28T04:35:16-04:00 INFO [alpine] Detecting vulnerabilities... os_version="3.21" repository="" pkg_num=17
2026-05-28T04:35:16-04:00 INFO Number of language-specific files num=1
2026-05-28T04:35:16-04:00 INFO [node-pkg] Detecting vulnerabilities...
2026-05-28T04:35:16-04:00 WARN Using severities from other vendors for some vulnerabilities. Read https://trivy.dev/docs/v0.70/guide/scanner/vulnerability#severity-selection for details.
2026-05-28T04:35:16-04:00 INFO Table result includes only package filenames. Use "--format json" option to get the full path to the package file.

Report Summary
```

Target	Type	Vulnerabilities
sbom.json (alpine 3.21.3)	alpine	50
app/node_modules/@eslint-community/eslint-utils/node_modules/eslint-visitor-keys/package.json	node-pkg	0
app/node_modules/@eslint-community/eslint-utils/package.json	node-pkg	0
app/node_modules/@eslint-community/regexpp/package.json	node-pkg	0
app/node_modules/@eslint/config-array/package.json	node-pkg	0
app/node_modules/@eslint/config-helpers/package.json	node-pkg	0
app/node_modules/@eslint/core/package.json	node-pkg	0
app/node_modules/@eslint/js/package.json	node-pkg	0
app/node_modules/@eslint/object-schema/package.json	node-pkg	0
app/node_modules/@eslint/plugin-kit/package.json	node-pkg	0
app/node_modules/@humanfs/core/package.json	node-pkg	0
app/node_modules/@humanfs/node/package.json	node-pkg	0
app/node_modules/@humanfs/types/package.json	node-pkg	0
app/node_modules/@humanwhocodes/module-importer/package.json	node-pkg	0
app/node_modules/@humanwhocodes/retry/package.json	node-pkg	0
app/node_modules/@types/esrecurse/package.json	node-pkg	0

Se realiza un análisis de vulnerabilidades basado en el SBOM generado, permitiendo evaluar los riesgos asociados a las dependencias del software de manera independiente al entorno de ejecución.

VULNERABLE (ENTORNO INSEGURO)

- **SAST**

Se ha realizado un análisis SAST sobre la aplicación vulnerable utilizando la herramienta npm audit. El resultado muestra múltiples vulnerabilidades críticas y de severidad alta en dependencias como express, body-parser, qs, cookie y send. Estas vulnerabilidades incluyen problemas de denegación de servicio, prototype pollution y posibles fallos de inyección. El análisis confirma que la versión vulnerable del proyecto no cumple requisitos de seguridad y expone riesgos conocidos en su cadena de dependencias.

```
iriscarlina@carolina:~/vulnerable$ npm audit --audit-level=low
# npm audit report

body-parser <=1.20.2
Severity: high
body-parser vulnerable to denial of service when url encoding is enabled - https://github.com/advisories/GHSA-qecr-r2fa-qrc7
Depends on vulnerable versions of qs
Fix available via npm audit fix
node_modules/express/node_modules/body-parser
  express <=4.21.0 || 5.0.0-alpha.1 - 5.0.0
  Depends on vulnerable versions of body-parser
  Depends on vulnerable versions of cookie
  Depends on vulnerable versions of path-to-regexp
  Depends on vulnerable versions of qs
  Depends on vulnerable versions of send
  Depends on vulnerable versions of serve-static
node_modules/express

cookie <=0.7.0
cookie accepts cookie name, path, and domain with out of bounds characters - https://github.com/advisories/GHSA-pvg6-pf52-xh8x
Fix available via npm audit fix
node_modules/cookie

path-to-regexp <=0.1.12
Severity: high
path-to-regexp outputs backtracking regular expressions - https://github.com/advisories/GHSA-9wv6-86v2-598j
path-to-regexp contains a ReDoS - https://github.com/advisories/GHSA-ph6-c781-4qdw
path-to-regexp vulnerable to Regular Expression Denial of Service via multiple route parameters - https://github.com/advisories/GHSA-37ch-88jc-xw2
Fix available via npm audit fix
node_modules/path-to-regexp

qs <=6.14.0
Severity: high
qs vulnerable to Prototype Pollution - https://github.com/advisories/GHSA-hrpp-h998-13pp
qs's array.limit bypass in its bracket notation allows DoS via memory exhaustion - https://github.com/advisories/GHSA-6rw7-vpxm-498p
Fix available via npm audit fix
node_modules/express/node_modules/qs

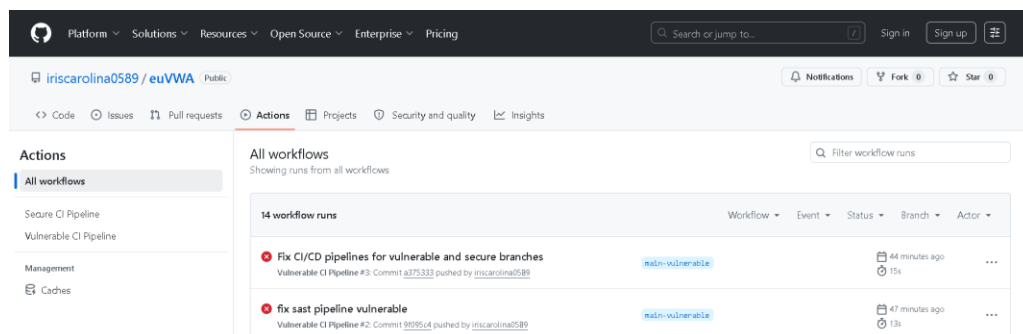
send <=0.19.0
send vulnerable to template injection that can lead to XSS - https://github.com/advisories/GHSA-m6fv-jmcg-4jfg
Fix available via npm audit fix
node_modules/send
  serve-static <=1.16.0
  Depends on vulnerable versions of send
node_modules/serve-static

7 vulnerabilities (3 low, 4 high)

To address all issues, run:
npm audit fix
```

- **CI/CD Pipeline**

Se ha implementado un pipeline de integración continua (CI/CD) en GitHub Actions para el análisis SAST automático del código vulnerable. El pipeline ejecuta npm audit con umbral de severidad alta. Debido a la presencia de múltiples vulnerabilidades en las dependencias del proyecto, el pipeline falla correctamente, impidiendo la integración del código inseguro. Esto demuestra la efectividad del control automatizado de seguridad en el ciclo de desarrollo.



- **DAST - Análisis dinámico**

Se realizó un análisis dinámico de seguridad utilizando OWASP ZAP en modo baseline sobre la aplicación vulnerable ejecutándose en local.

El escaneo se lanzó mediante Docker contra la URL:

<http://localhost:3000>

El análisis identificó múltiples advertencias de seguridad (WARN), relacionadas principalmente con la ausencia de cabeceras HTTP de seguridad, entre ellas:

- Falta de Content Security Policy (CSP)
- Ausencia de cabeceras anti-clickjacking
- Falta de X-Content-Type-Options
- Ausencia de Permissions Policy

Estas vulnerabilidades indican una mala configuración de seguridad, que podría ser explotada en ataques reales.

Cabe destacar que no se detectaron vulnerabilidades críticas, debido a que el escaneo solo alcanzó la ruta principal de la aplicación y no profundizó en todas las funcionalidades vulnerables implementadas.

Esto demuestra la importancia de complementar el análisis DAST con pruebas más profundas o autenticadas.

```
Windows PowerShell
PS C:\Users\Mario> cd C:\Users\Mario\euVWA\main-vulnerable
PS C:\Users\Mario\euVWA\main-vulnerable> docker run -t -v ${PWD}:/zap/wrk ghcr.io/zaproxy/zaproxy:stable zap-baseline.py
-t http://host.docker.internal:3000 -r zap-vulnerable.html
Using the Automation Framework
Total of 3 URLs
PASS: Vulnerable JS Library (Powered by Retire.js) [10003]
PASS: In Page Banner Information Leak [10009]
PASS: Cookie No HttpOnly Flag [10010]
PASS: Cookie Without Secure Flag [10011]
PASS: Re-examine Cache-control Directives [10015]
PASS: Cross-Domain JavaScript Source File Inclusion [10017]
PASS: Content-Type Header Missing [10019]
PASS: Information Disclosure - Debug Error Messages [10023]
PASS: Information Disclosure - Sensitive Information in URL [10024]
PASS: Information Disclosure - Sensitive Information in HTTP Referrer Header [10025]
PASS: HTTP Parameter Override [10026]
PASS: Information Disclosure - Suspicious Comments [10027]
PASS: Off-site Redirect [10028]
PASS: Cookie Poisoning [10029]
PASS: User Controllable Charset [10030]
PASS: User Controllable HTML Element Attribute (Potential XSS) [10031]
PASS: Viewstate [10032]
PASS: Directory Browsing [10033]
PASS: Heartbleed OpenSSL Vulnerability (Indicative) [10034]
PASS: Strict-Transport-Security Header [10035]
PASS: HTTP Server Response Header [10036]
PASS: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037]
PASS: X-Backend-Server Header Information Leak [10039]
PASS: Secure Pages Include Mixed Content [10040]
PASS: HTTP to HTTPS Insecure Transition in Form Post [10041]
PASS: HTTPS to HTTP Insecure Transition in Form Post [10042]
PASS: User Controllable JavaScript Event (XSS) [10043]
PASS: Big Redirect Detected (Potential Sensitive Information Leak) [10044]
PASS: Retrieved from Cache [10050]
PASS: X-ChromeLogger-Data (XCOLD) Header Information Leak [10052]
PASS: Cookie without SameSite Attribute [10054]
PASS: CSP [10055]
PASS: X-Debug-Token Information Leak [10056]
PASS: Username Hash Found [10057]
PASS: X-AspNet-Version Response Header [10061]
```

```
! clyml JS app.js main-securev... JS app.js main-vulnerablev... Dockerfile U zap-vulnerable.html U X
main-vulnerable > zap-vulnerable.html > ...
1 |<DOCTYPE html>
2 |<html>
3 |<head>
4 |<META http-equiv="Content-Type" content="text/html; charset=UTF-8" />
5 |<title>ZAP Scanning Report</title>
6 |<style type="text/css">
7 |body {
8 |    font-family: "Helvetica Neue", Helvetica, Arial, sans-serif;
9 |    color: #000;
10 |    font-size: 13px;
11 |}
12 |
13 |h1 {
14 |    text-align: center;
15 |    font-weight: bold;
16 |    font-size: 32px;
17 |}
18 |
19 |h3 {
20 |    font-size: 16px;
21 |}
22 |
23 |table {
24 |    border: none;
25 |    font-size: 13px;
26 |}
27 |
28 |td, th {
29 |    padding: 3px 4px;
30 |    word-break: break-word;
31 |}
32 |
33 |th {
34 |    font-weight: bold;
35 |    background-color: #666666;
36 |}
37 |
```

Nota:

El análisis DAST mediante OWASP ZAP baseline muestra resultados similares en ambas ramas debido a que el escaneo se basa en comportamiento HTTP observable y no en el código fuente. Las diferencias entre las versiones vulnerable y secure están más relacionadas con la lógica interna y controles de seguridad aplicados en endpoints específicos, los cuales no siempre son detectados por un escaneo baseline pasivo.

Imágenes Docker

```
Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ docker tag euVWA-vulnerable iriscarolinaafg/euVWA-vulnerable

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ docker tag euVWA-secure iriscarolinaafg/euVWA-secure

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ docker push iriscarolinaafg/euVWA-vulnerable
Using default tag: latest
The push refers to repository [docker.io/iriscarolinaafg/euVWA-vulnerable]
c1f87426c994: Pushed
f18232174bc9: Pushed
41d5bca55585: Pushed
75784d3082ed: Pushed
39cc6f2424df: Pushed
46092fbAAF26: Pushed
25ff2da83641: Pushed
dd71dde834b5: Pushed
1e5a4c89cee5: Pushed
8187ded3466c: Pushed
352fa6dec34d: Pushed
latest: digest: sha256:67275e89d449e01f0adee90c1299ca2f410d03e4221c36d60da20888a2a07225 size: 856

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$ docker push iriscarolinaafg/euVWA-secure
Using default tag: latest
The push refers to repository [docker.io/iriscarolinaafg/euVWA-secure]
2550a7c7d710: Pushed
bd4286c60c80: Pushed
4b74f6712675: Pushed
d887295b4396: Pushed
1e5a4c89cee5: Mounted from iriscarolinaafg/euVWA-vulnerable
25ff2da83641: Mounted from iriscarolinaafg/euVWA-vulnerable
b5734eff7855: Pushed
f18232174bc9: Mounted from iriscarolinaafg/euVWA-vulnerable
6167232f2ec9: Pushed
dd71dde834b5: Mounted from iriscarolinaafg/euVWA-vulnerable
a1d0741d7e5c: Pushed
latest: digest: sha256:3918e7d4563c89a60197869278b660c9af47d8cbcd500ae4d24d04e167e71db size: 856

Mario@DESKTOP-RUB30FD MINGW64 ~/euVWA (main-vulnerable)
$
```

Images

Give feedback

Local

My Hub

iriscarlinaafg

Q

Search

[View Docker Scout dashboard](#)

Tags	OS	Vulnerabilities	Last pushed	Size	Actions
iriscarlinaafg/euvwa-se... latest		Inactive	6 minutes ago	75.54 MB	Pull
iriscarlinaafg/euvwa-vu... latest		Inactive	7 minutes ago	77.49 MB	Pull

Repositories per page

5

1 - 2 of 2

Se construyeron dos imágenes Docker para el proyecto: una versión vulnerable y otra versión secure. La imagen vulnerable contiene dependencias desactualizadas para simular riesgos reales, mientras que la versión secure aplica hardening básico y buenas prácticas de seguridad. Ambas imágenes fueron escaneadas con Trivy para identificar vulnerabilidades en el sistema operativo y dependencias.

Imágenes publicadas en Docker Hub

Secure:

<https://hub.docker.com/r/iriscarolinaafg/euvwa-secure>

Vulnerable:

<https://hub.docker.com/r/iriscarolinaafg/euvwa-vulnerable>